

SÍNTESIS DE LA CLASE

1

Repaso: seguridad y privacidad de la información

Siete ideas centrales para analizar casos y elegir controles.

1. Proteger

Datos, servicios e identidades.

2. Detectar

Debilidades y amenazas.

3. Responder

Controles, trazabilidad y mejora.

Objetivo: pasar de términos aislados a lectura de casos.

CONCEPTOS BASE

2

Marco conceptual: de activo a incidente

Activo

Elemento con valor.
Debe protegerse.

Vulnerabilidad

Debilidad que puede
ser explotada.

Amenaza

Actor o situación
que puede causar daño.

Incidente

Amenaza concretada
o inminente.

CIA: Confidencialidad · Integridad · Disponibilidad

Pregunta guía: ¿qué activo y qué impacto?

CONTEXTO HISTÓRICO

Evolución: de equipos aislados a ecosistemas con IA

La defensa ya no protege solo computadoras: protege servicios, datos, nubes, proveedores, usuarios e IA.



Idea clave: ataques y defensa se profesionalizan.

Criptografía: controles esenciales

Simétrica

Una clave compartida.
Datos en reposo y backups.

Asimétrica

Clave pública/privada.
Certificados, SSH y TLS.

Hash

Huella de integridad.
No cifra. Evitar MD5/SHA-1.

Firma digital

Integridad, autenticidad
y no repudio.

Clave: implementación correcta y gestión segura de claves.

Autenticación

Contraseñas con hash robusto.

MFA para cuentas críticas.

Passkeys/FIDO2 contra phishing.

Claves y secretos

Separar claves por uso.

Usar KMS, HSM, Vault o TPM.

No guardar secretos en chats o repos.

Principio transversal: mínimo privilegio y auditoría.

Privacidad digital: rastros, datos y derechos

Rastros digitales

Cookies, ubicación, IP, apps e IoT.

Dataficación

La vida cotidiana se vuelve dato.

Identidad digital

Credenciales, publicaciones e interacciones.

Principios

Finalidad, minimización, transparencia y seguridad.

Pregunta ética: ¿quién controla los datos y para qué?

Amenazas actuales y respuesta a incidentes

Amenazas a reconocer

Phishing, BEC y abuso de MFA.

Ransomware, DDoS y fuga de datos.

Supply chain, Shadow AI y deepfakes.

Respuesta ordenada

Antes: inventario, MFA, backups.

Durante: aislar, contener, evidenciar.

Después: recuperar y mejorar controles.

Consigna: activo · amenaza · CIA · mitigación.

AGENDA 2da clase

Qué vamos a trabajar hoy

De la infraestructura a la aplicación, y de la seguridad técnica al gobierno institucional.

- 1 Amenazas y vulnerabilidades por capas OSI: cómo ubicar un problema.
- 2 OWASP como mapa práctico de riesgos para web, APIs, móviles, cloud, IoT, blockchain y LLMs.
- 3 Regulación, cumplimiento y gobierno: Cybersecurity Act, NIS2, CRA, CER, política institucional, SOC y CSIRT.

BLOQUE 1

Amenazas por capas OSI

El modelo OSI sirve como mapa conceptual para ubicar controles y fallas: no todos los ataques nacen en la aplicación.

OSI como herramienta de análisis

Un caso puede cruzar varias capas: separar ayuda a diagnosticar y a decidir controles.

7 Aplicación

6 Presentación

5 Sesión

4 Transporte

3 Red

2 Enlace

1 Física

Capas bajas: disponibilidad, acceso físico, red, segmentación y configuración.

Capas medias: sesiones, transporte seguro, TLS, control de estado y replay.

Capas altas: autenticación, autorización, validación de entradas, lógica de negocio y privacidad.

Idea clave: la mitigación más efectiva combina controles técnicos, procesos y capacitación.

CAPAS 1–2

Física y enlace: donde empieza la confianza

Amenazas de acceso físico, LAN y Wi-Fi.

Capa 1 • Física

Manipulación de cables, routers o servidores; robo de hardware; interferencia electromagnética; firmware desactualizado.

Ejemplo: cortar fibra para causar denegación de servicio.

Capa 2 • Enlace

ARP spoofing, MAC flooding, VLAN hopping, rogue access points y suplantación de MAC.

Controles: control físico, inventario, 802.1X, hardening, segmentación y monitoreo de red.

CAPAS 3–4

Red y transporte: disponibilidad, rutas y sesiones

El problema ya no es solo ‘quién entrá’, sino cómo circula el tráfico.

Capa 3 · Red

IP spoofing, DDoS, ICMP flood, ataques de routing, escaneo de puertos y firewalls/ACLs mal configurados.

DDoS afecta disponibilidad; spoofing puede afectar confidencialidad e integridad.

Capa 4 · Transporte

SYN flood, session hijacking, replay, conexiones inseguras y ataques contra TCP/UDP.

Controles: rate limiting, protección DDoS, TLS, firewalls, IDS/IPS y revisión de reglas.

CAPAS 5–6

Sesión y presentación: identidad, estado y criptografía

En estas capas aparecen fallas de sesión, datos sensibles y uso incorrecto de cifrado.

Capa 5 · Sesión

Session fixation, predicción de ID, sesiones largas, no invalidar logout, CSRF y credenciales débiles.

Controles: cookies seguras, expiración/revocación de tokens y CSRF tokens.

Capa 6 · Presentación

Fallas criptográficas, TLS débil, exposición de datos sensibles y manipulación de integridad.

Controles: TLS 1.2/1.3, Argon2id/bcrypt/scrypt, HSTS y gestión de claves.

CAPA 7

Aplicación: donde OWASP se vuelve central

La mayoría de los riesgos visibles para usuarios y datos aparece en servicios, APIs y lógica de negocio.

Inyección SQL/NoSQL/OS Command: entrada no validada que altera una consulta o comando.

Broken Access Control: usuarios acceden a recursos o funciones que no les corresponden.

Authentication Failures: gestión débil de credenciales, tokens o sesiones.

Security Misconfiguration: configuraciones por defecto, consolas expuestas o permisos excesivos.

Regla práctica: no confiar en la entrada, no confiar en el cliente, no confiar en permisos implícitos.

BLOQUE 2

OWASP como mapa práctico

OWASP no es una lista de nombres: es un conjunto de guías para diseñar, desarrollar, probar y operar software seguro.

OWASP

Qué es y por qué importa

Open Web Application Security Project: comunidad abierta para mejorar la seguridad del software.

Referencia de industria para desarrolladores, equipos de seguridad y gestión.

Aporta listas de riesgos, estándares, guías, herramientas y metodologías abiertas.

Cubre web, móvil, APIs, cloud native, IoT, blockchain, LLMs y GenAI.

Usamos ejemplos de bajo nivel, no explotables, con foco en remediaciones, detección y diseño seguro.

PRINCIPIOS

Principios transversales de seguridad

Sirven para web, móvil, APIs, cloud, IoT, IA y cualquier sistema conectado.

Menor privilegio

Solo permisos necesarios, por el menor tiempo posible.

Defensa en profundidad

Varias capas para que una falla no sea fatal.

Secure by design

Seguridad desde requisitos y arquitectura.

Fail securely

Ante el error, caer en un estado seguro.

Zero Trust

No confiar por ubicación; verificar de forma continua.

Logging y monitoreo

Registrar eventos y responder a tiempo.

TOP 10

OWASP Top 10:2025 RC1 — lectura resumida

Lista base para pensar riesgos de aplicaciones web.

A01	Broken Access Control	A02	Security Misconfiguration
A03	Software Supply Chain Failures	A04	Cryptographic Failures
A05	Injection	A06	Insecure Design
A07	Authentication Failures	A08	Software/Data Integrity Failures
A09	Logging & Alerting Failures	A10	Mishandling of Exceptional Conditions

La lista 2025 RC1 reordena el énfasis: configuración, supply chain, logging y manejo de excepciones ganan mayor peso operativo.

A01–A05: riesgos, ejemplos y mitigaciones

Una lectura rápida para análisis de casos.

A01 Acceso

IDOR/BOLA: cambiar /users/102 para ver otro usuario. Mitigación: autorización por recurso y pruebas.

A02 Config.

Consola admin expuesta o bucket público. Mitigación: hardening, IaC seguro y escaneo.

A03 Supply chain

Dependencia crítica sin parchear. Mitigación: SBOM, SCA y updates planificados.

A04 Cripto

Contraseñas en texto claro o TLS débil. Mitigación: TLS moderno, Argon2id y KMS/Vault.

A05 Injection

Entrada altera consultas o comandos. Mitigación: prepared statements y validación.

A06–A10: diseño, identidad, integridad y operación

La seguridad también falla por diseño y por falta de respuesta.

A06 Diseño

Sin límites de intentos o roles mal pensados. Mitigación: threat modeling.

A07 Auth

JWT sin expiración o sesiones no revocadas. Mitigación: MFA, expiración y cookies seguras.

A08 Integridad

Pipeline descarga artefactos sin verificar. Mitigación: firmas, hashes y protección CI/CD.

A09 Logging

No registrar cambios de privilegio o logins fallidos. Mitigación: logs mínimos, alertas y retención.

A10 Excepciones

Stack trace con rutas o secretos en producción. Mitigación: manejo seguro de errores.

OWASP API Security Top 10: riesgos típicos

Las APIs son la cara de muchos servicios y un vector de ataque creciente.

BOLA/BFLA: no verificar permisos sobre objetos o funciones específicas.

Broken Authentication: tokens, contraseñas o claves API mal gestionadas.

Unrestricted Resource Consumption: falta de límites que habilita DoS o abuso de costos.

SSRF: el servidor es engañado para hacer peticiones no autorizadas.

Improper Inventory Management: endpoints viejos o versiones no controladas.

Control clave: autorización por recurso + límites + inventario + monitoreo.

El perímetro se distribuye

El sistema no termina en el servidor web.

Mobile / MASVS

Almacenamiento inseguro, comunicación sin cifrar, auth débil, reverse engineering y protección insuficiente del binario.

Cloud native

Configuración de nube/contenedores, CI/CD, secretos, políticas de red, cuotas de cómputo y logging.

IoT

Contraseñas por defecto, servicios inseguros, updates débiles, privacidad insuficiente y falta de hardening físico.

Pregunta común: ¿qué superficie de ataque agregamos al pasar de una aplicación web a una app móvil, un contenedor o un dispositivo conectado?

LLM / GENAI

OWASP para LLMs y GenAI

La IA introduce riesgos nuevos y amplifica riesgos clásicos.

Riesgos principales

Prompt injection, insecure output handling, exposición de información sensible, excessive agency y overreliance.

También aparecen riesgos en RAG, conectores, memoria y herramientas externas.

Control principal

Separar instrucciones, datos no confiables y acciones privilegiadas. Aplicar mínimo privilegio, sandboxing y supervisión humana.

Registrar prompts, tool-calls, versión de modelo, conectores, datos y decisiones.

BLOQUE 3

Regulación, cumplimiento y gobierno

Los marcos regulatorios conectan la seguridad técnica con responsabilidades institucionales, auditoría, evidencia y resiliencia.

Cybersecurity Act y actualización 2024/2847

Marco europeo para reforzar la confianza y seguridad en el mercado digital.

Reglamento (UE) 2019/881

Conocido como Cybersecurity Act. Crea un marco común de certificación para productos, servicios y procesos TIC.

Autoridad principal: ENISA, Agencia de la Unión Europea para la Ciberseguridad.

Enmienda 2024/2847

Amplía el alcance a productos con componentes digitales y a servicios de seguridad gestionados.

Ejemplos: hardware inteligente, software embebido, IoT, SOC, CSIRT, MDR y MSSP.

DE 2019 A 2024

Qué cambia con la actualización

La regulación desplaza el foco desde “producto seguro” hacia ciclo de vida, certificación y servicios gestionados.

Introduce requisitos para productos con componentes digitales: IoT, software embebido, hardware inteligente.

Extiende esquemas de certificación a servicios de seguridad gestionados: SOC, CSIRT, MDR y MSSP.

Refuerza el rol de ENISA como autoridad de evaluación, coordinación y referencia técnica.

Amplía el alcance del marco de certificación a proveedores y servicios críticos para la confianza digital.

Mensaje para clase: vender o desplegar tecnología en ecosistemas regulados exige evidencia de seguridad desde el diseño.

CERTIFICACIÓN

EUROPEA

Tres niveles de garantía

La certificación permite comunicar el nivel de seguridad esperado y verificado.

Básico

Controles mínimos y autoevaluación. Adecuado para riesgos acotados o productos de bajo impacto.

Sustancial

Auditorías independientes y gestión de riesgos. Orientado a servicios o productos con mayor exposición.

Alto

Validación estricta, pruebas y supervisión continua. Enfocado en entornos críticos o de alto impacto.

Aplicable a dispositivos conectados, plataformas de software, servicios cloud y proveedores de servicios de seguridad gestionados.

IMPACTO EN EL ECOSISTEMA

Implicancias para industria y profesionales TIC

La ciberseguridad deja de ser solo una función técnica: se transforma en requisito de mercado, contratación y confianza.

Las empresas deberán demostrar cumplimiento de estándares de seguridad para comercializar en la UE.

Desarrolladores y proveedores de TI deben integrar security by design durante todo el ciclo de vida.

Se fomenta interoperabilidad y confianza digital entre Estados miembros.

Abre oportunidades profesionales en evaluación, auditoría, certificación, gestión de riesgos y servicios de seguridad.

Ecosistema involucrado: fabricantes, proveedores, autoridades, usuarios, auditores y equipos técnicos.

Normas complementarias: NIS2, CRA y CER

Tres marcos europeos que refuerzan seguridad, continuidad y resiliencia de entidades y productos.

NIS2 · UE 2022/2555

Obliga a sectores esenciales e importantes a gestionar riesgos e incidentes: energía, transporte, salud, educación, administración y otros.

CRA · 2024

Cyber Resilience Act: productos con elementos digitales deben diseñarse con seguridad integrada y mantenimiento durante el ciclo de vida.

CER · UE 2022/2557

Critical Entities Resilience Directive: resiliencia física y digital de infraestructuras críticas esenciales.

Idea de integración: seguridad del producto + resiliencia operativa + continuidad de entidades críticas.

De los marcos al gobierno institucional

Una política traduce objetivos, responsabilidades y controles en reglas comunes para toda la organización.

Referencias institucionales

Modelo de Política de Seguridad de la Información para Organismos Públicos.

Requisitos mínimos de Seguridad de la Información para Organismos: Decisión Administrativa 641/2021.

Política de seguridad de la información de las Instituciones Universitarias Públicas: Resolución C.E. CIN 1669/22.

Qué debe resolver

Alcance, roles y responsabilidades, clasificación de información, gestión de riesgos, control de accesos, continuidad, incidentes, proveedores y concientización.

La política debe ser aplicable, auditable y revisable.

Roles para implementar la política

Gobernar ciberseguridad requiere responsabilidades claras y articulación entre áreas.

CISO y Comité de Ciberseguridad

El CISO reporta a la alta gerencia y define estrategia, políticas, cumplimiento, gestión de riesgos y coordinación con IT, SOC, CSIRT y Legal.

El Comité aporta priorización institucional, seguimiento y articulación entre áreas.

CPO / Privacidad

El CPO o responsable de privacidad coordina protección de datos, criterios de tratamiento, derechos de titulares y evaluación de impacto.

Debe trabajar con seguridad, legales, gestión académica y sistemas.

SOC Y CSIRT

Operación, detección y respuesta

La estructura técnica convierte la política en capacidad real de detección, contención, recuperación y aprendizaje.

SOC · Security Operations Center

Monitoreo en tiempo real, SIEM, IDS/IPS, EDR, correlación de eventos, detección inicial, alertas y reportes.

Objetivo: ver temprano, priorizar y escalar.

CSIRT · Incident Response Team

Gestión completa de incidentes: detección, contención, erradicación, recuperación, análisis forense, coordinación externa y lecciones aprendidas.

Objetivo: responder, documentar y mejorar.

CIERRE

Cómo leer un caso en la clase

Del incidente al aprendizaje: activo, capa, riesgo, regulación y respuesta.

- 1 ¿Qué activo se afecta?
- 2 ¿Qué capa o superficie interviene?
- 3 ¿Qué vulnerabilidad o mala práctica habilita el ataque?
- 4 ¿Qué principio OWASP o control aplica?
- 5 ¿Qué obligación de privacidad, evidencia o reporte aparece?
- 6 ¿Quién responde: IT, CISO, CPO, SOC, CSIRT, Legal?